

NIST SP 800-61 Incident Report

Golden Ticket Attack Chain: Incident Response and Forensic Evidence Lab

Prepared by David Mokom | Project 1 | Isolated Active Directory Lab

Field	Details
Report Type	Controlled lab incident response report
Framework	NIST SP 800-61 Rev. 2 - Computer Security Incident Handling Guide
Environment	Isolated Active Directory lab
Domain	cs.local
Host	WIN-HS48GJMN0GP
Primary Scenario	Golden Ticket attack simulation and defender-side evidence review
Status	Lab completed; evidence reviewed; limitations documented

Important Scope Note

This report documents a controlled security lab, not a real production incident. The wording is intentionally evidence-based. Findings are tied to the screenshots and artifacts available in the project repository. Items that were not directly proven by screenshots are described as supporting review areas or future improvements rather than confirmed production-grade detection coverage.

1. Executive Summary

This report documents a Golden Ticket attack simulation performed in an isolated Active Directory lab. The purpose was to understand how KRBTGT compromise can be used to create a forged Kerberos ticket, how that ticket can be validated, and what evidence a defender could review during investigation and remediation.

The lab included memory capture, controlled Mimikatz execution, KRBTGT hash extraction, Golden Ticket creation and injection, Kerberos ticket validation, administrative share access validation, Elastic and Windows log review, KRBTGT remediation evidence, and supporting forensic review using Edge browser history and Volatility 3.

The main incident response lesson was that the attack itself is only one side of the work. The stronger defender skill is understanding what evidence the activity creates, validating that evidence, explaining what it proves, and clearly stating the limitations.

Topic	Evidence-Based Summary
Golden Ticket validation	The forged ticket was created, injected, and validated with klist. Access to the Domain Controller administrative share was also tested.
Elastic review	Elastic supported review of Mimikatz-related evidence. This should not be overstated as full automatic detection of the entire attack chain.
KRBTGT remediation	Windows Security Event IDs 4724 and 4738 supported password reset and account modification evidence.
File activity telemetry	Elastic showed high-volume file activity under a RansomwareTest path. This is ransomware-style telemetry, not confirmed ransomware impact by itself.

Topic	Evidence-Based Summary
Volatility review	Volatility 3 windows.pslist supported basic memory process review, not deep memory malware analysis.

2. NIST SP 800-61 Phase 1 - Preparation

The preparation phase established the isolated Active Directory environment, validated the tools needed for the simulation, and defined how evidence would be collected and interpreted.

2.1 Lab Environment

Component	Details
Domain Controller	Windows Server 2022
Hostname	WIN-HS48GJMN0GP
Domain	cs.local
Authentication model	Active Directory / Kerberos
SIEM / log review	Elastic / Kibana and Windows Security logs
Memory capture	FTK Imager
Memory review	Volatility 3 windows.pslist
Browser artifact review	Microsoft Edge History SQLite database

2.2 Tools Prepared

Tool	Purpose in This Lab
FTK Imager	Captured memory from the Windows Server system for later review.
Mimikatz	Used in the controlled lab to extract the KRBTGT hash, create a Golden Ticket, and inject the ticket.
Elastic / Kibana	Reviewed Mimikatz-related evidence and file activity telemetry.
Windows Security Event Logs	Reviewed KRBTGT password reset and account modification evidence.
DB Browser for SQLite	Opened the Edge History database as a supporting forensic artifact.
Volatility 3	Used windows.pslist for basic process-list memory triage.

2.3 Evidence Handling Approach

- Screenshot paths and filenames were preserved so the repository evidence remains linkable.
- Elastic evidence was described as investigation support, not proof of complete detection coverage.
- File activity telemetry was described as ransomware-style activity, not confirmed ransomware impact by itself.
- Volatility output was described as process-list triage only, because the visible screenshot does not prove deep memory analysis or Mimikatz presence in memory.
- KRBTGT remediation claims were limited to what the screenshots support: Event ID 4724 and Event ID 4738.

3. NIST SP 800-61 Phase 2 - Detection and Analysis

This phase covers what happened during the simulated compromise, what evidence was reviewed, and what each artifact supports.

3.1 Memory Capture

FTK Imager was used to capture memory from the Windows Server system. The memory capture created an artifact for later review with Volatility. This supported basic forensic triage, but it should not be described as complete memory forensics.

Evidence	Interpretation
01_FTK_Baseline_Memory_Capture.png	FTK memory capture was configured.
02_FTK_Memory_Capture_Success.png	The memory capture completed successfully.

3.2 Defender Disabled for Controlled Execution

Defender real-time protection was disabled so Mimikatz could execute inside the lab. This was a controlled lab condition. In a real environment, endpoint protection being disabled would itself be suspicious and should be investigated.

Evidence	Interpretation
03_Windows_Defender_Disabled.png	Defender real-time protection was disabled for lab execution.

3.3 Mimikatz Execution and Debug Privilege

Mimikatz was extracted, launched from an elevated session, and debug privilege was enabled. This supported the credential access portion of the lab and established the point where a defender would care about process execution, LSASS access, command-line visibility, and endpoint telemetry.

Evidence	Interpretation
04_Mimikatz_Files_Extracted.png	Mimikatz files were extracted.
05_Mimikatz_Initialization.png	Mimikatz launched successfully.
06_Mimikatz_Debug_Privilege_Enabled.png	privilege::debug returned successfully.

3.4 KRBTGT Hash Extraction

The KRBTGT hash and domain SID were captured for the Golden Ticket simulation. The KRBTGT account is important because it signs Kerberos Ticket Granting Tickets. If this hash is compromised, forged Kerberos tickets may be created and accepted by the domain.

Artifact	Value
KRBTGT NTLM hash used in lab	4c89c456b825f173d94aefc94d8718bd
Domain SID	S-1-5-21-426635828-459186537-2548376310
Supporting screenshot	07_KRBTGT_Hash_Dumped.png

3.5 Golden Ticket Creation, Injection, and Validation

A forged Kerberos ticket was created and saved as golden.kirbi, then injected into the current session. The ticket was validated with klist before access was tested against a domain resource.

Evidence	Interpretation
08_Golden_Ticket_Forged.png	Golden Ticket was created and saved as golden.kirbi.
09_Golden_Ticket_Injected.png	Ticket was injected using pass-the-ticket behavior.
10_God_Mode_Verification.png	Despite the filename, the professional interpretation is Kerberos ticket validation with klist.

3.6 Administrative Share Access Validation

After the ticket was loaded, access to the Domain Controller administrative share was tested. The successful directory listing showed the forged ticket was usable against a privileged domain resource in the lab.

Evidence	Interpretation
11_Golden_Ticket_Injection_Verification.png	Session and group context were reviewed after ticket injection.
12_Post_Exploitation_Access_Validation.png	The administrative share \\WIN-HS48GJMN0GP\C\$ returned a directory listing.

3.7 Elastic and Windows Log Review

Elastic was reviewed for Mimikatz-related evidence. This is useful investigation evidence, but it should not be described as proof that the entire attack chain was automatically detected. The accurate conclusion is that Elastic supported investigation and pivoting around Mimikatz-related activity.

Evidence	Interpretation
13_SIEM_Alert_Mimikatz_Detection.png	Elastic review of Mimikatz-related evidence.

3.8 Supporting Forensic Review

Area	Evidence-Based Interpretation
File activity telemetry	The screenshot showed high-volume file activity under a RansomwareTest path. This is ransomware-style telemetry, not confirmed ransomware impact by itself.
Edge browser history	The Edge History database was located and opened in DB Browser for SQLite. This supports timeline reconstruction practice.
Volatility 3	windows.pslist returned process-list output. This supports basic memory triage, not deep memory malware analysis.

4. NIST SP 800-61 Phase 3 - Containment, Eradication, and Recovery

Because this was a controlled lab, containment and recovery are described as lab response actions rather than production incident response. The main remediation focus was KRBTGT reset evidence and understanding what should be monitored afterward.

4.1 Containment Considerations

- Stop active testing and preserve screenshots and logs before making remediation changes.
- Treat the forged ticket session as untrusted in the lab context.
- Review available Elastic and Windows logs before resetting KRBTGT so evidence is not lost or confused with remediation activity.

4.2 KRBTGT Remediation

The KRBTGT account password was reset in Active Directory. Windows Security logs were then reviewed for account password reset and account modification evidence.

Evidence	Meaning
14_KRBTGT_Password_Reset_Remediation.png	KRBTGT password reset action in Active Directory.
15_KRBTGT_Remediation_Log_Validation.png	Event ID 4724 - an attempt was made to reset an account's password.
16_KRBTGT_Account_Modified_Event_4738.png	Event ID 4738 - a user account was changed.

In a real environment, KRBTGT remediation must be staged carefully because Active Directory keeps current and previous KRBTGT password material for Kerberos validation. This lab report does not claim production replication validation or full enterprise-wide eradication.

4.3 Recovery Considerations

- Validate authentication behavior after KRBTGT reset activity.
- Monitor for authentication failures and privileged account anomalies after remediation.
- Review KRBTGT account changes and password reset events as part of the incident timeline.
- Preserve Elastic screenshots, Windows Event Log screenshots, browser history artifacts, and Volatility output as lab evidence.

5. NIST SP 800-61 Phase 4 - Post-Incident Activity

5.1 Lessons Learned

Lesson	Explanation
KRBTGT compromise is high-impact	The KRBTGT account signs Kerberos Ticket Granting Tickets. If its hash is compromised, forged Kerberos tickets can be created.
Validation matters	Creating the ticket was not enough. The lab validated the loaded ticket with klist and then tested access to a privileged resource.
Elastic evidence needs careful interpretation	Related evidence in Elastic supports investigation, but one screenshot should not be overstated as complete detection coverage.
Remediation creates evidence	Event IDs 4724 and 4738 supported the KRBTGT remediation timeline.
Forensic artifacts need context	File activity, browser history, and memory process output can support an investigation, but none should be treated as complete proof alone.

5.2 Evidence Registry

Evidence Item	Supported Conclusion
01-02 FTK screenshots	Memory capture was configured and completed.
03 Defender screenshot	Defender real-time protection was disabled for controlled lab execution.
04-06 Mimikatz screenshots	Mimikatz was staged, launched, and debug privilege was enabled.
07 KRBTGT hash screenshot	KRBTGT hash and domain SID were captured for the lab simulation.
08-10 Golden Ticket screenshots	Ticket was created, injected, and validated with klist.
11-12 Access validation screenshots	Session context and administrative share access were tested.

Evidence Item	Supported Conclusion
13 Elastic screenshot	Elastic review supported Mimikatz-related investigation.
14-16 KRBTGT remediation screenshots	Password reset and account modification evidence was reviewed.
17 File activity screenshot	High-volume file activity telemetry was reviewed.
18-19 Edge screenshots	Edge History database was located and opened for review.
20 Volatility screenshot	Volatility windows.pslist returned process-list output.

5.3 Improvement Plan

- Separate pre-attack and post-attack memory captures with clearer filenames.
- Add Sysmon logging for stronger process and command-line visibility.
- Capture more specific Elastic screenshots for DCSync, SMB share access, Kerberos anomalies, and LSASS access if available.
- Build a clearer timeline mapping attack actions to log evidence and remediation actions.
- Use additional Volatility plugins beyond windows.pslist for deeper memory analysis.
- Keep ransomware-style file telemetry separate from the core Golden Ticket evidence unless stronger impact evidence is collected.

6. Final Assessment

The lab successfully demonstrated the core Golden Ticket workflow in an isolated Active Directory environment and tied the activity to defender-side evidence. The strongest supported findings are the KRBTGT hash extraction, forged ticket creation and injection, Kerberos ticket validation, administrative share access validation, KRBTGT remediation events, and supporting artifact review.

The report intentionally avoids overstating the evidence. Elastic review is framed as Mimikatz-related investigation rather than full detection coverage. File activity is framed as ransomware-style telemetry rather than confirmed ransomware impact. Volatility is framed as basic process-list triage rather than deep memory forensics. This makes the report more accurate, easier to defend, and better aligned with the screenshot evidence.

End of Report

Report Author: David Mokom
Project Reference: Project 1
Framework: NIST SP 800-61 Rev. 2
Report Status: Final - Lab Documentation